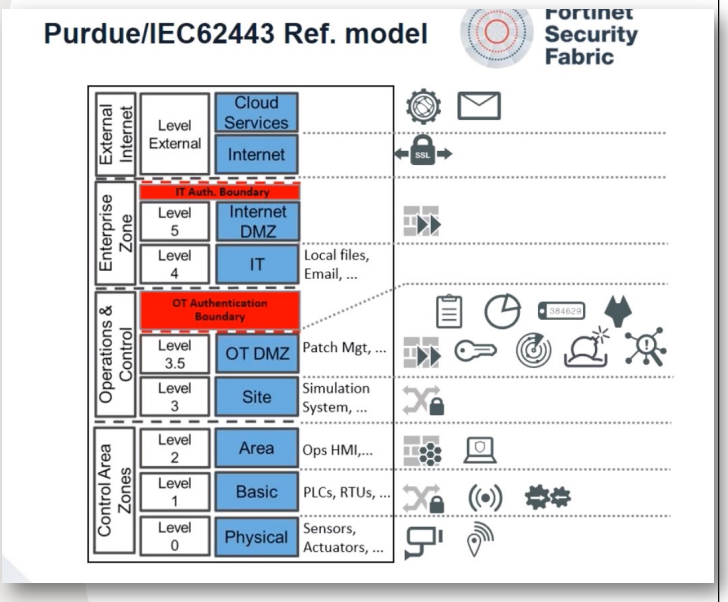
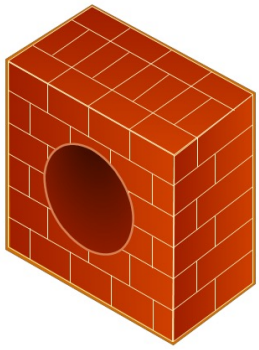
Zonmodellen

Purdue / IEC62443



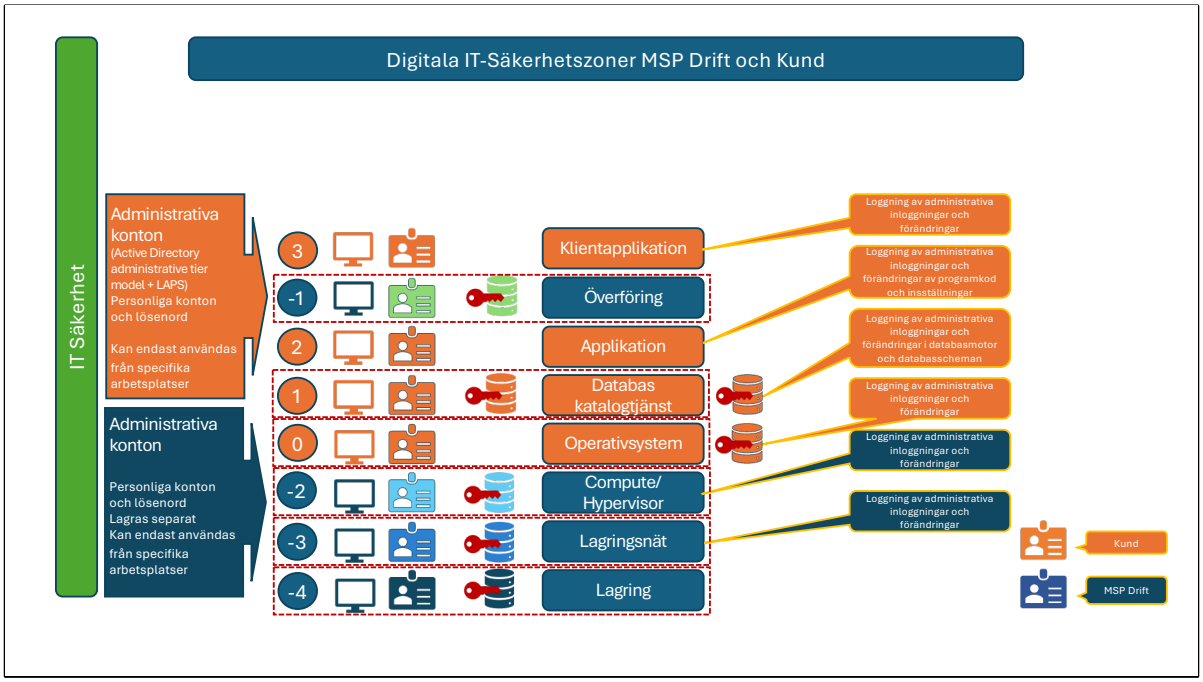
Firewall: Skydd eller möjliggörare

- Möjliggör kommunikation mellan segment
- Möjliggör exponering av sårbarheter i exponerad tjänst
- Erbjuder genom tex UPnP möjlighet att dynamiskt öppna upp brandväggen
- Kan, om den är en NGFW, känna igen okrypterat innehåll och blockera detta



Vad känner Brandväggen till om innehållet i TCP/UDP som åker igenom hålet? Idag är det mesta krypterat så egentligen släpper brandväggen in/igenom vem som hels med vilken bra eller dålig agenda genom sitt hål.

Hemma möjliggör Routern/Brandväggen åtkomst till Internet men blockerar åtkomst till dina lokala datorer förutom när man har UPnP aktiverat då en lokal dator kan begära brandväggsöppning från Internet till en tjänst på din lokala dator utan att be om lov

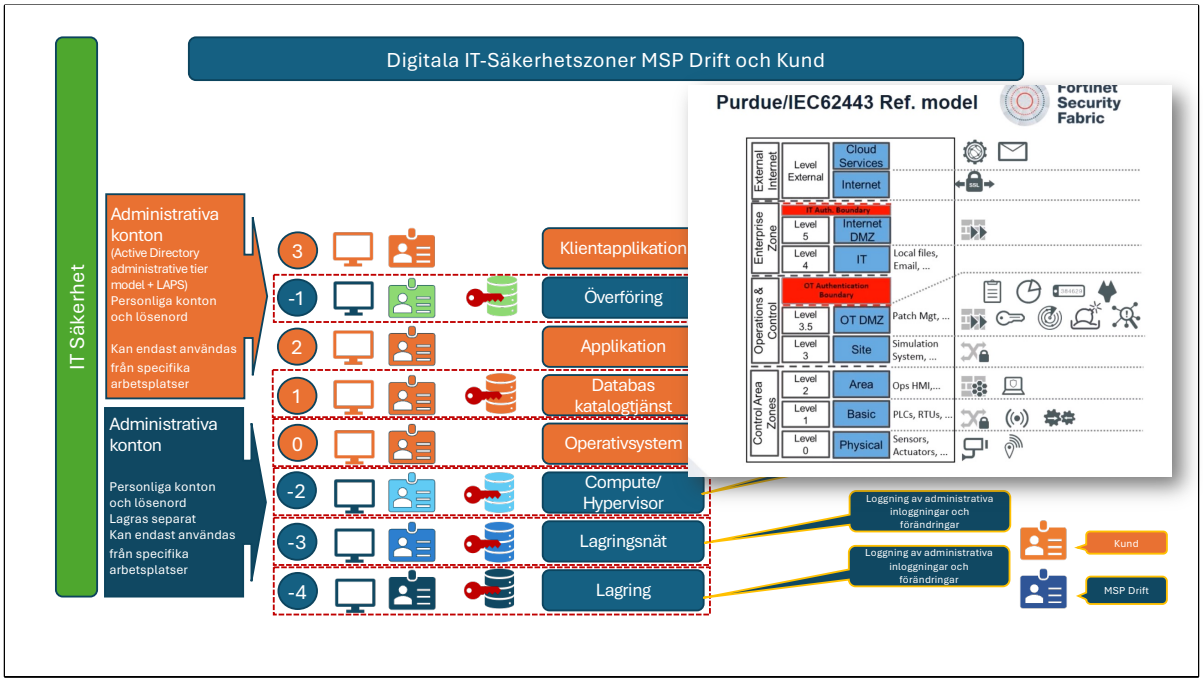


Vi har 3 olika mjukvarutillverkare i lagringslösningarna för att inte ha samma sårbarheter i all lagring och backup.
IBM, Pure, VMWare.
Tillkommer Microsoft som kundens information lagras i.

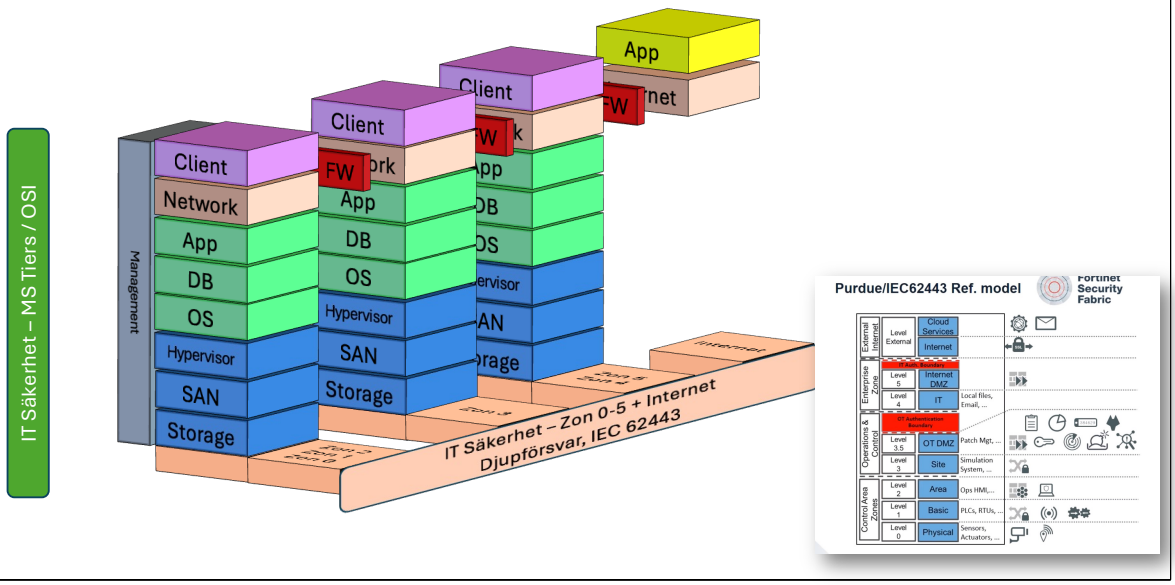
Här redovisas en matris med relationer till kontohantering och säkerhetszoner.
Administrativa konton i de olika zonerna lagras i separata kontodatabaser.
Kontona kan endast användas från specificerade arbetsplatser som är geografiskt knutna till olika säkerhetszoner hos MSP Drift

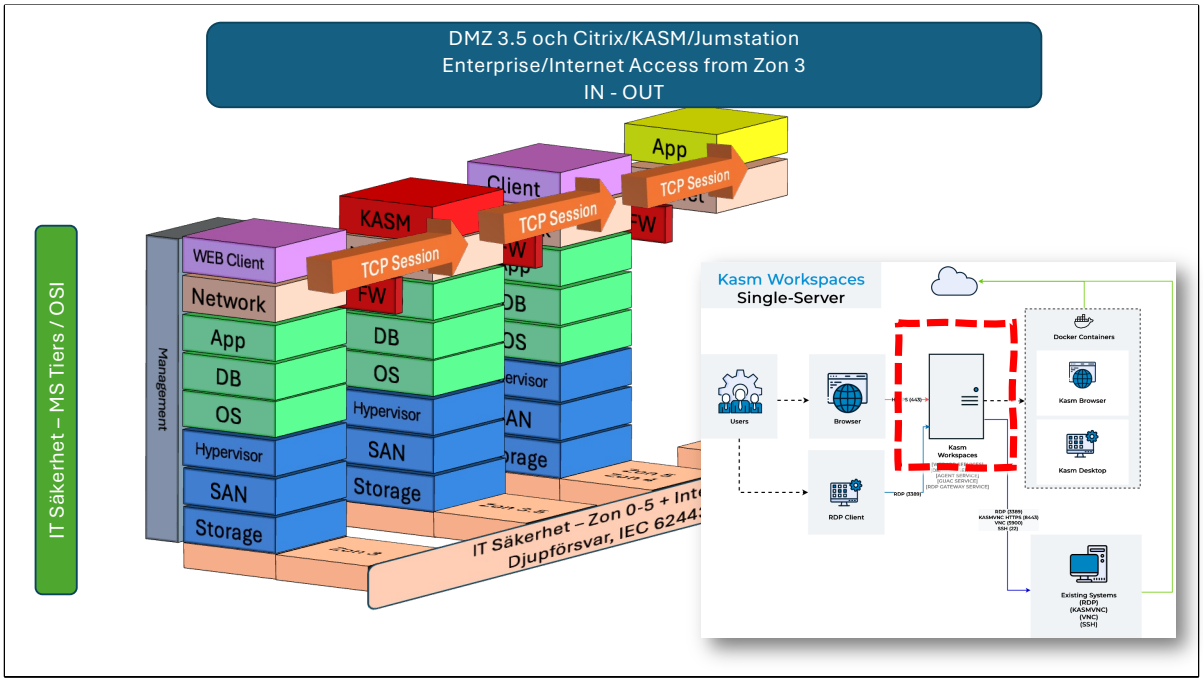
Microsofts modell ” Active Directory administrative tier model” är applicerad på kundens miljö
https://docs.microsoft.com/en-us/windows-server/identity/securing-privileged-access/securing-privileged-access-reference-material

Även Microsofts lösning ”LAPS” appliceras:
https://support.microsoft.com/en-us/help/3062591/microsoft-security-advisory-local-administrator-password-solution-laps

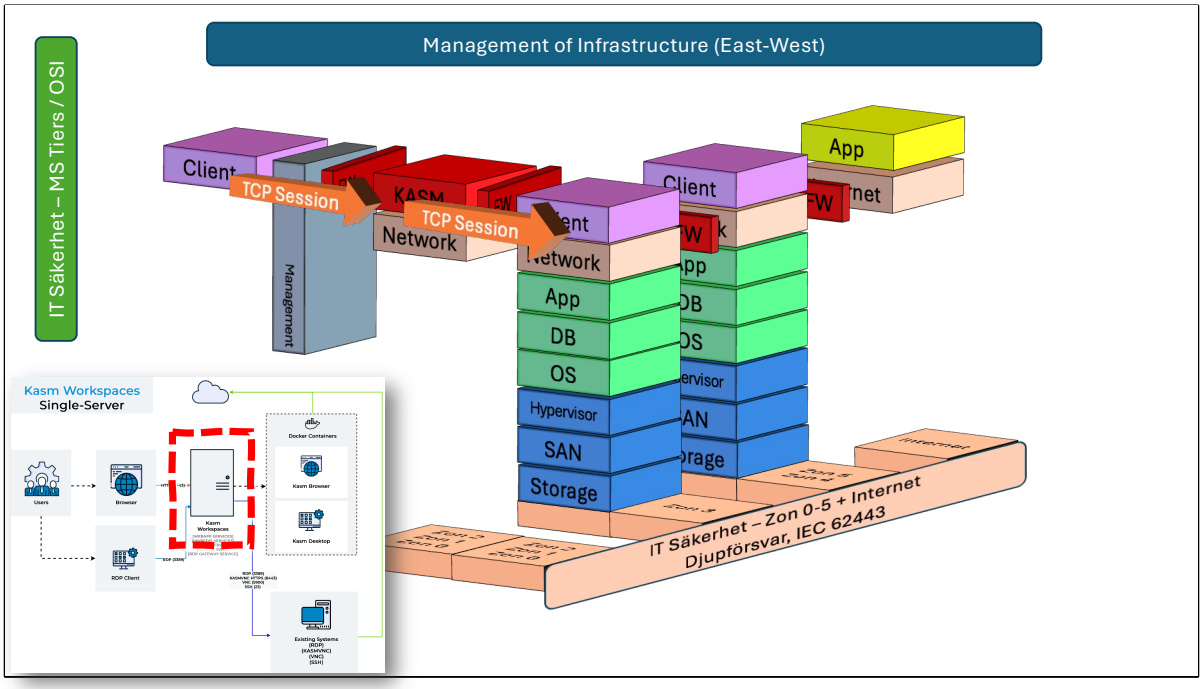

Digitala IT-Säkerhetszoner MSP Drift och Kund
IT Säkerhet
Administrativa konton
(Active Directory administrative tier model + LAPS)
Personliga konton och lösenord
Kan endast användas från specifika arbetsplatser
Administrativa konton
Personliga konton och lösenord
Lagras separat
Kan endast användas från specifika arbetsplatser
3
-1
2
1
0
-2
-3
-4
Klientapplikation
Överföring
Applikation
Databas katalogtjänst
Operativsystem
Compute/ Hypervisor
Lagringsnät
Lagring
Purdue/IEC62443 Ref. model
Fortinet Security Fabric
External Internet
Level External
Cloud Services
Internet
Enterprise Zone
IT Auth. Boundary
Level 5
Internet DMZ
Level 4
IT
Local files, Email, ...
Operations & Control
OT Authentication Boundary
Level 3.5
OT DMZ
Patch Mgt, ...
Level 3
Site
Simulation System, ...
Control Area Zones
Level 2
Area
Ops HMI,...
Level 1
Basic
PLCs, RTUs, ...
Level 0
Physical
Sensors, Actuators, ...
Loggning av administrativa inloggningar och förändringar
Loggning av administrativa inloggningar och förändringar
Kund
MSP Drift

IT-Säkerhetszoner i förhållande till OSI, ”OSI for Applications”





Vid varje byte av Zon så bryts TCP samt protokollet, tex RDP/HTTPS.
KASM container etablerar en ny HTTPS/RDP session och speglar bara skärmbilden vidare till kienten i Zon 3.
Klippa o Klistra är blockerat mellan Zonerna likväl filöverföring



För att kunna använda samma infrastruktur för hantering/management av olika Zoner så kan en Management Zon etableras vid sidan om Zon 0-5 enligt principen ovan.